



RASTRO

Trazabilidad verificable de envíos

Sergio Montoya · Nicolás Torres · Oscar Rincón
Cloud Computing (ISD38) · Grupo 30112

BLOQUE 1

Presentación del sistema

- 2 Contexto y necesidad
- 3 Qué es el sistema
- 4 Por qué importa



Contexto y necesidad

Organización. Empresa de mensajería urbana de pequeño tamaño en Bogotá, con flota reducida y clientes corporativos.

El estado de un envío vive hoy en cuatro sitios a la vez: la memoria del mensajero, un chat, una hoja de cálculo y la llamada del despachador.

No existe un registro que diga quién cambió el estado, cuándo y con qué respaldo.



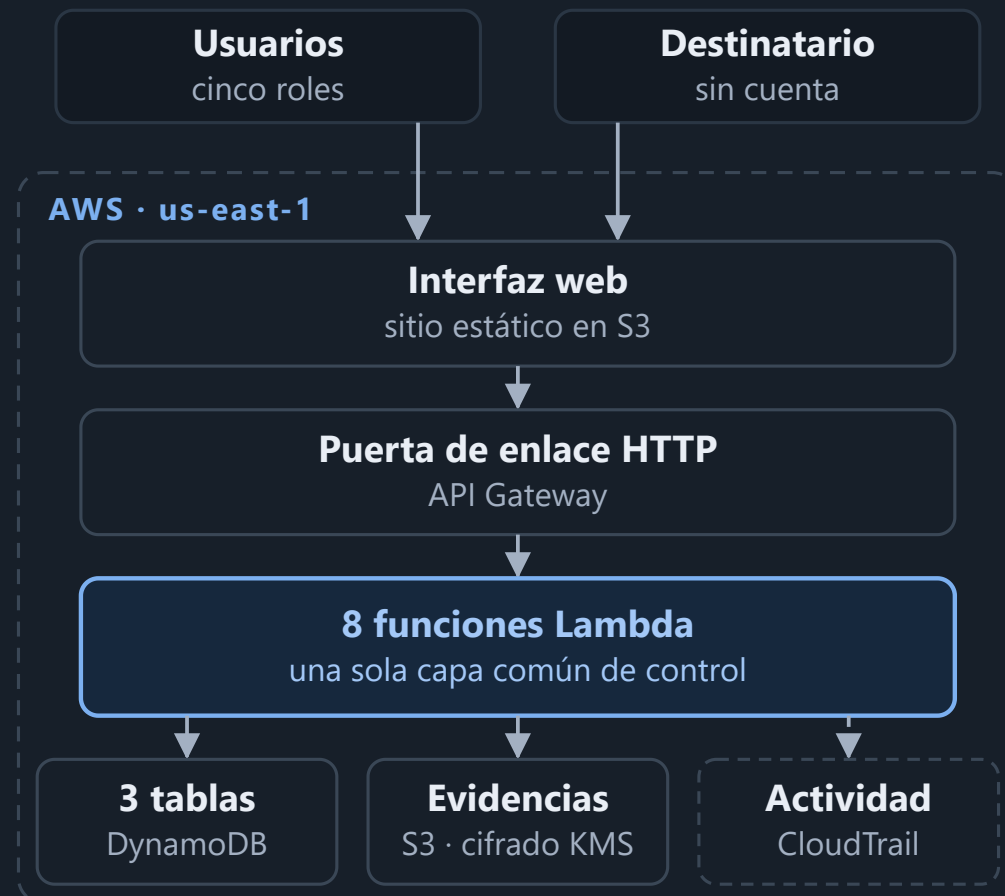
Qué es el sistema

Rastro traslada ese registro a un sistema que obliga a que cada cambio quede **atribuido, fechado y validado** contra un conjunto de transiciones permitidas.

Desplegado en AWS: ocho funciones, tres tablas, almacén cifrado, registro de actividad.

Infraestructura compartida entre varias empresas, con datos aislados.

Cuenta 484948252891 · us-east-1



Por qué importa

Consecuencia hoy	Efecto
Las reclamaciones se resuelven por acuerdo, no por consulta	Se asume el costo sin poder demostrar lo contrario
El despachador reconstruye información por teléfono	Tiempo operativo en una tarea sin valor
No se puede acreditar que el procedimiento se cumplió	Se pierden clientes que lo exigen

Sobre la evidencia del problema: procede de la experiencia laboral del equipo, declarada con sus limitaciones en el documento. Es observación no sistemática y así está escrito.



BLOQUE 2

Planificación

- 5 Objetivos
- 6 Alcance y exclusiones
- 7 Responsables, recursos y cronograma
- 8 Actividades realizadas



Objetivos

General. Desarrollar un sistema que registre de forma **verificable** el ciclo de vida de cada envío, con control de acceso por rol, aislamiento entre organizaciones y evidencia de entrega cifrada.

Específicos

1. Caracterizar el proceso actual y sus puntos de pérdida de información
2. Diseñar arquitectura y modelo de datos según las restricciones del entorno
3. Construir y desplegar sobre servicios gestionados
4. Verificar mediante pruebas que los controles funcionan

La palabra que carga el peso es *verificable*: no que funcione, sino que cualquiera pueda comprobarlo.



Alcance y exclusiones

Dentro	Fuera
Ciclo de vida del envío con identificador no predecible	Registro autónomo de organizaciones
Consulta pública sin autenticación	Rastreo por posición continua del vehículo
Evidencia de entrega cifrada	Optimización de rutas
Aislamiento entre organizaciones	Aplicación móvil nativa
Autorización por rol con registro del intento	Notificaciones automáticas
Bitácora encadenada y despliegue reproducible	

Condicionado y no logrado: retención inmutable del almacén. El entorno no la permitió y se declara.



Responsables, recursos y cronograma

Fase	Semanas	Responsable	Estado
Diagnóstico y validación de supuestos	1–2	Oscar Rincón	Cerrada
Diseño	3–4	Sergio Montoya	Cerrada
Construcción y despliegue	5–9	Nicolás Torres · Sergio Montoya	Cerrada
Verificación y cierre	10–12	Oscar Rincón	En curso

Recursos. Presupuesto de 50 dólares por cuenta. Único cargo fijo: la llave de cifrado. Se excluyen deliberadamente los recursos que facturan entre sesiones.



Actividades realizadas

- Pruebas preliminares sobre permisos y exposición del entorno
- Once decisiones de arquitectura registradas antes de implementarlas
- Ocho servicios, dos interfaces web y capa común de control
- Secuencia de despliegue idempotente con verificación posterior
- 238 pruebas automatizadas escritas junto con el código
- Despliegue y verificación completa el 26 de septiembre



BLOQUE 3

Metodología

- 9 Enfoque y regla que lo sostuvo
- 10 Técnicas empleadas y por qué



Enfoque y regla que lo sostuvo

Enfoque **iterativo e incremental** en cuatro fases, una por objetivo específico.

Regla que gobernó todo el trabajo:

**Ningún requisito se dio por cumplido
antes de tener su prueba automatizada.**

Eso convirtió la verificación en parte de la construcción y no en una fase posterior. Por eso la suite creció al mismo ritmo que el sistema.



Técnicas empleadas y por qué

Técnica	Para qué	Por qué esa
Registro de decisiones de arquitectura	Documentar antes de implementar	Evita que el código y el documento se contradigan
Prueba mínima de capacidad	Validar supuestos del entorno	Comprobar antes de construir sobre una capacidad
Pruebas unitarias	Reglas independientes de la infraestructura	Rápidas y sin credenciales
Pruebas de extremo a extremo	Requisitos sobre la pila completa	Organizadas por requisito, no por módulo
Verificación posterior al despliegue	Que cada componente exista y responda	Código de salida automatizable
Auditoría independiente	Que los controles funcionen	Quien despliega no debe concluir que el control está bien



BLOQUE 4

Riesgos y controles

- 11 Activos identificados
- 12 Riesgos, probabilidad e impacto
- 13 Controles implementados
- 14 Controles faltantes
- 15 Roles y permisos
- 16 Matriz de permisos · envíos y operación
- 17 Matriz de permisos · administración y auditoría
- 18 Reglas de los roles que no se pueden configurar



Activos identificados

Activo	Por qué importa
Datos de envíos y destinatarios	Información personal de terceros
Evidencias de entrega	Prueba de la cadena de custodia
Bitácora de auditoría	Sostiene el no repudio del sistema
Llave de cifrado	Compromete todas las evidencias
Secreto de firma de sesiones	Permite suplantar cualquier rol

Decisión de privacidad: el sistema se pobló **solo con datos sintéticos**.

Ningún dato personal real entró al sistema.



Riesgos, probabilidad e impacto

Riesgo	Prob.	Impacto	Estado
Consulta sin filtrar por organización	Media	Muy alto	No materializado
Exposición de secretos	Media	Muy alto	Materializado y corregido
El laboratorio bloquea un servicio previsto	Media	Alto	Materializado y resuelto
El alcance crece y no se termina	Alta	Alto	Materializado y gestionado
Se agota el presupuesto de la cuenta	Media	Alto	No materializado
Identificador literal impide migrar	Media	Alto	No materializado



Controles implementados

Amenaza	Control	Verificado por
Acceso a datos de otra organización	Clave de partición ORG#...#ENV#... y capa común única	Control C-06
Operación por rol no autorizado	Autorización por operación, con registro del intento	Control C-05
Enumeración desde la consulta pública	Identificadores aleatorios, no consecutivos	Diseño · OWASP A01
Alteración del histórico	Bitácora encadenada + condición de no existencia + registro de actividad	Control C-08
Evidencias legibles por terceros	Cifrado con llave propia, rotación y bloqueo público	Controles C-02 y C-03

El aislamiento no depende de que el programador recuerde filtrar: sin el identificador de organización, la consulta no se puede construir.



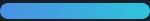
Controles faltantes

El entorno impide construirlos, y se declaran en lugar de omitirse:

Rol de ejecución por función. Las ocho comparten un rol amplio. Incumple el principio de mínimo privilegio.

Ancla de integridad fuera de la cuenta. Frente a quien administra la cuenta, la arquitectura ofrece **detección**, no prevención.





Roles y permisos

Rol	Puede	No puede
Administrador	Todo: envíos, catálogos, cuentas y roles	Leer la bitácora
Coordinador	Despachar, reanudar incidencias, editar catálogos	Administrar cuentas; leer bitácora
Despachador	Crear y asignar envíos, registrar eventos	Reanudar incidencias; editar catálogos
Conductor	Ver sus envíos, marcar avance, cargar evidencia	Crear o asignar envíos
Auditor	Consultar y leer la bitácora	Cualquier operación de escritura

Ningún rol combina escritura con lectura de la bitácora, y ninguna cuenta puede sumar dos roles que juntos lo hagan. No es configurable.

Los roles se definen en datos, no en código: una empresa puede crear roles propios eligiendo de la lista de operaciones, nunca inventando operaciones nuevas.



Matriz de permisos · envíos y operación

Operación	Administrador	Coordinador	Despachador	Conductor	Auditor
Registrar envíos, uno a uno o en lote	✓	✓	✓	—	—
Asignar mensajero y ver toda la operación	✓	✓	✓	—	—
Ver el listado de envíos	✓	✓	✓	Solo suyos	—
Abrir un envío y su histórico	✓	✓	✓	✓	✓
Marcar el avance del envío	✓	✓	✓	Solo suyos	—
Autorizar un envío detenido por incidencia	✓	✓	—	—	—
Adjuntar la prueba de entrega	✓	—	—	Solo suyos	—
Consultar las evidencias cargadas	✓	✓	✓	—	✓

Quien detiene no es quien reanuda: el conductor reporta la incidencia; autorizar la continuación corresponde a otro rol.



Matriz de permisos · administración y auditoría

Operación	Administrador	Coordinador	Despachador	Conductor	Auditor
Ver las cuentas de la empresa	✓	✓	—	—	✓
Crear cuentas	✓	—	—	—	—
Cambiar rol, datos o estado de una cuenta	✓	—	—	—	—
Ver los roles y sus permisos	✓	—	—	—	✓
Crear roles y cambiar sus permisos	✓	—	—	—	—
Ver los mensajeros disponibles	✓	✓	✓	—	—
Ver tiendas, clientes y transportistas	✓	✓	✓	✓	✓
Modificar tiendas, clientes y transportistas	✓	✓	—	—	—
Ver el tablero de indicadores	✓	✓	✓	✓	✓
Leer la bitácora	—	—	—	—	✓
Verificar la integridad de la cadena	—	—	—	—	✓

De 19 operaciones: Administrador 17 · Coordinador 12 · Despachador 9 ·
Conductor 6 · Auditor 8



Reglas de los roles que no se pueden configurar

Regla	Qué evita
El administrador conserva siempre sus 17 operaciones y su rol no se edita	Que una edición deje a la empresa sin nadie que pueda corregirla
Ningún rol ni cuenta combina escritura con lectura de la bitácora	Que quien opera revise su propio rastro
Nadie concede un permiso que no tiene	La autopromoción: el intento queda en la bitácora como escalada de privilegios
Sin permiso de asignar, solo se actúa sobre los envíos propios	Que un mensajero marque avance o cargue evidencia en envíos ajenos

Todo intento, permitido o rechazado, queda en la bitácora.

Cada regla tiene su prueba en `tests/e2e/test_roles.py` y `tests/unit/test_autorizacion_y_claves.py`.



BLOQUE 5

Normativas

- 19 Estándares aplicados
- 20 Cumplimientos e incumplimientos



Estándares aplicados

Marco	Qué exige	Cómo se cumple
Ley 1581 de 2012 y Decreto 1377	Tratamiento de datos personales	Minimización, cifrado, acceso por rol. Solo datos sintéticos
ISO/IEC 27001:2022 A.8.24 y A.8.13	Criptografía y copias	Llave propia con rotación; versionado
CIS AWS Benchmark	Configuración segura de la cuenta	Registro con validación de integridad; sin acceso público
OWASP Top 10:2021 A01	Control de acceso	Identificadores aleatorios; 404 y no 403 entre organizaciones
NIST SP 800-92	Registros de seguridad	La bitácora conserva actor, acción, recurso y momento
AWS Well-Architected, seguridad	Mínimo privilegio	No se cumple. Declarado como hallazgo permanente



Cumplimientos e incumplimientos

Verificado por una **auditoría independiente**, ejecutada por un programa distinto contra el sistema desplegado:

11

controles

10

conformes

1

desviado

0

sin ejecutar

Incumple: un secreto permanece en el historial del repositorio, ya invalidado.

Incumple, sin posibilidad de corregir aquí: mínimo privilegio.



BLOQUE 6

Hallazgos y evidencias

- 21 Evidencia · Pruebas automatizadas
- 22 Evidencia · Despliegue verificado
- 23 Hallazgo · El incidente del secreto
- 24 Trazabilidad de las evidencias



Evidencia · Pruebas automatizadas

234

superadas

4

omitidas

0

fallos

14

segundos

Conjunto	Pruebas
Unitarias	84
Extremo a extremo	120
Programa de auditoría	34

No requieren credenciales ni contenedores. **Cualquiera puede repetirlos.**

Evidencia · Despliegue verificado

Seis grupos comprobados, código de salida 0, el 26/09/2026:

- tres tablas, llave de cifrado, dos contenedores
- las ocho funciones
- puerta de enlace y registro de actividad
- consulta pública a través de la interfaz: **404 esperado**
- catálogo de estados: responde

El 404 no es un error: es una **prueba negativa** que confirma la ruta completa.



Hallazgo · El incidente del secreto

Condición	Un secreto de firma quedó publicado en el repositorio durante 27 minutos
Criterio	ISO/IEC 27001 A.5.17 y A.8.4
Causa	La exclusión existía y se retiró en bloque al versionar las evidencias
Riesgo	Cualquiera podría firmar un token con rol de administrador
Evidencia	<code>evidencias-despliegue/20260926T232257Z-rotacion-secreto.txt</code>

Corrección. Rotación, redespliegue de las ocho funciones, comprobación de rechazo y exclusión. Sin indicios de explotación en la ventana.

Lo detectó el equipo al revisar el despliegue: ningún control cubría los secretos. Desde entonces lo vigila uno automatizado, C-09.



Trazabilidad de las evidencias

Evidencia	Origen	Fecha
Verificación del despliegue	95-verificar.sh , código de salida 0	26/09/2026
Suite de pruebas	python -m pytest -q	Reproducible
Rotación del secreto	Comparación de huellas, sin exponer valores	26/09/2026
Auditoría de controles	Ejecución ...235724886Z-4f87a8	26/09/2026

Cada una con comando, salida completa y fecha, en el repositorio.



BLOQUE 7

Conclusiones y mejoras

- 25 Resultados generales
- 26 Acciones correctivas
- 27 Limitaciones declaradas
- 28 Cierre



Resultados generales

- Los **nueve requisitos** comprometidos se cumplen y pueden comprobarse
- **Tres verificaciones independientes** llegan a la misma conclusión: pruebas, despliegue y auditoría externa
- Tres riesgos se materializaron; los tres se gestionaron y se documentan
- El incidente del secreto se detectó a mano y dejó un control automatizado que antes no existía: C-09



Acciones correctivas

Acción	Responsable	Prioridad	Tiempo
Reescribir el historial del repositorio	Nicolás Torres	Alta	2 horas
Rol de ejecución por función	Sergio Montoya	Alta	1 semana · depende del entorno
Validar con una empresa real	Oscar Rincón	Alta	Un semestre
Ancla externa de la bitácora	Sergio Montoya	Media	3 semanas · depende del entorno
Concurrencia en el encadenamiento	Nicolás Torres	Media	1 semana
Derivación de contraseñas más resistente	Nicolás Torres	Baja	1 semana



Limitaciones declaradas

Sin usuarios reales. Demostramos que el sistema funciona, no que resuelva el problema en operación.

Mínimo privilegio incumplido. El entorno no permite crear roles.

Integridad: detección, no prevención. Frente a quien administra la cuenta, la arquitectura detecta la alteración pero no la impide.



Cierre

Las restricciones del entorno no fueron un obstáculo: fueron el insumo de diseño.

- Sin cómputo persistente → arquitectura bajo demanda
- Entorno volátil → despliegue reproducible
- Sin roles propios → la limitación más importante, declarada y no disimulada

Ningún requisito se cerró sin su prueba.

github.com/Serann10255/Rastro

